Protection des Données à Caractère Personnel – Contenu de formation

Auteurs : François Daoust (fd@sbc4d.com), Stéphane Boyera (stephane@sbc4d.com)

Date : Avril 2020

CC BY NC SA

Table des Matières

Table des Matières 2
Introduction 3
Définition 3
La protection des données personnelles en Afrique et dans le monde 6
Le contexte législatif Ivoirien 8
Mise en œuvre opérationnel de la protection des données personnelles 13
Les entités et les activités qui relèvent de la protection des données personnelles 13
Les démarches générales 14
Les démarches spécifiques pour la mise en place d'un nouveau traitement 15
Étape 1 : Conception d'un processus de collecte de données 16
Étape 2 : collecte de données 19
Étape 3 : Exploitation des données collectées 19
Conclusion 20
Evaluation 20
Références 20

Introduction

Les données à caractère personnel ne sont pas des données comme les autres car elles permettent d'identifier une personne de façon individuelle, et donc relève de l'intimité et de la vie privée de cette personne. Aujourd'hui un grand nombre de constitutions adoptées par des pays du monde entier reconnaisse le droit inaliénable à la vie privée et donc à la protection de ces données personnelles. Ces dispositions constitutionnelles sont souvent traduites dans des législations spécifiques. En Côte d'Ivoire, la Loi N°2013-450 du 19 Juin 2013 relative à la protection des données à caractère personnel[1] fournit un cadre légal pour la protection des données à caractère personnel. Ces législations ont le but unique de protéger les citoyens contre l'exploitation de leurs données personnelles à leur insu et parfois à leur détriment. Avec d'une part la digitalisation grandissante de l'ensemble des données gouvernementales ou du secteur privé, et d'autre part l'émergence de la société de l'information, et l'explosion des activités en ligne des citoyens que ce soit sur les réseaux sociaux, les sites web, les sites d'achat en ligne ou les moteurs de recherche, les moyens technologiques permettent à un grand nombre d'acteurs de collecter et d'exploiter un grand nombre de source de données personnelles. Afin de protéger la vie privée des citoyens, les législations et traités internationaux se sont renforcés au cours de la dernière décennie afin de prendre en compte l'univers numérique et les nouveaux risques qui ont émergés. De ce fait, aujourd'hui, il est fondamental pour tous les acteurs que ce soient des sociétés privées, des ONG, des associations, ou tout autre entité de bien comprendre le contenu de ces législations et d'intégrer dans leur opération leurs obligations et les contraintes qu'elles imposent dans le cadre de la collecte, du stockage, de la manipulation et du parage de données.

L'objectif de cette formation est d'une part de présenter en détail le contenu de la Loi N°2013-450 du 19 Juin 2013 relative à la protection des données à caractère personnel, et d'autre part de permettre aux participants de comprendre les implications opérationnelles à mettre en œuvre pour respecter les obligations inscrites dans la loi. Cette formation présente aussi un cadre plus large de la protection des données personnelles qui s'applique à d'autres pays que la Côte D'Ivoire. Ce cadre permettra aux participants qui souhaitent développer des activités dans d'autres pays d'avoir les outils nécessaires pour la mise en œuvre des dispositions spécifiques que ce pays pourrait avoir.

Définition

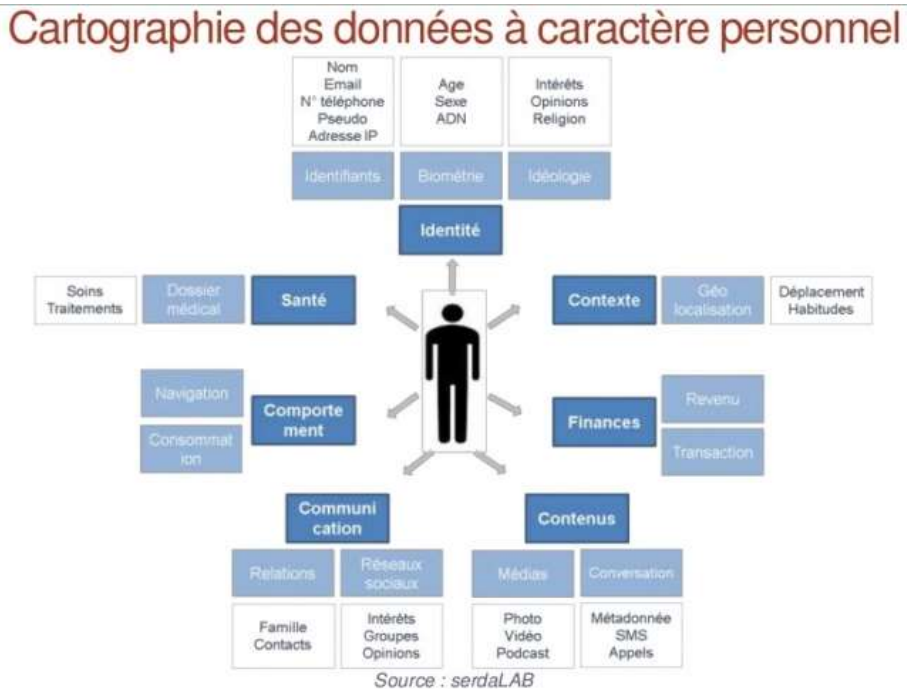
La définition commune des « données personnelles » est toute information qui rend une personne identifiable de manière unique. Ces informations peuvent prendre différents formats tels qu'un numéro d'identification (par exemple, numéro de sécurité sociale) ou un ou plusieurs facteurs spécifiques à son identité physique, physiologique, mentale, économique, culturelle ou sociale (par exemple, nom et prénom, date de naissance, données biométriques, empreintes digitales, ADN…). L'adresse précise définissant une seule personne

[1] *https://www.artci.ci/images/stories/pdf/lois/loi_2013_450.pdf*

ou des coordonnées GPS peuvent être également classés dans les données personnelles. L'image ci-dessous montre les types de données classées comme personnelles.



Le schéma ci-dessous donne une vue plus précise plus en lien avec les activités numériques :



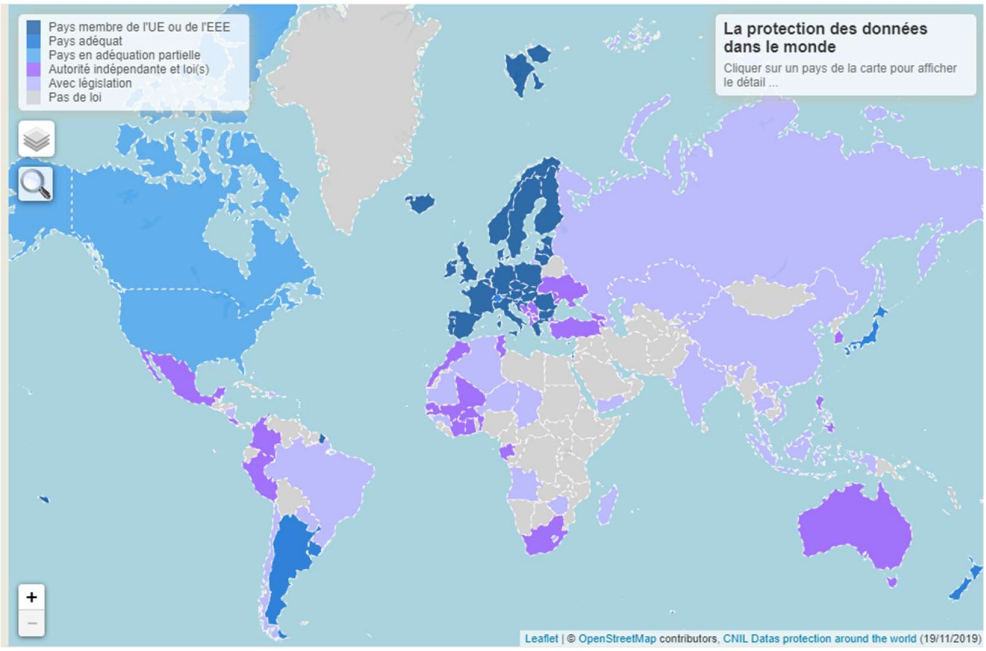
Dans le cadre de la loi N°2013-450, l'Article 1 donne la définition des données personnelles comme « toute information de quelque nature qu'elle soit et indépendamment de son support, y compris le son et l'image relative à une personne physique identifiée ou identifiable directement ou indirectement, par référence à un numéro d'identification ou à un ou plusieurs éléments spécifiques, propres à son identité physique, physiologique, génétique, psychique, culturelle, sociale ou économique ». Il est important de noter que certaines données, appelées « données sensibles » qui recouvrent « toutes données à caractère personnel relatives aux

opinions ou activités religieuse, philosophique, politique, syndicale, à la vie sexuelle ou raciale, à la santé, aux mesures d'ordre social, aux poursuites, aux sanctions pénales ou administratives » ne peuvent pas être collecté (Article 21) définit ces interdictions avec quelques exceptions :

- « Le traitement des données à caractère personnel porte sur des données manifestement rendues publiques par la personne concernée ;
- Le traitement des données génétiques ou relatives à l'état de santé est nécessaire à la sauvegarde des intérêts vitaux de la personne concernée ou d'une autre personne dans le cas où la personne concernée se trouve dans l'incapacité physique ou juridique de donner son consentement ;
- Le traitement, notamment des données génétiques, est nécessaire à la constatation, à l'exercice ou à la défense d'un droit en justice de la personne concernée ;
- Une procédure judiciaire ou une enquête pénale est ouverte. Dans ce cas le traitement des données à caractère personnel n'est poursuivi que pour la constatation des faits ou pour la manifestation de la vérité ;
- Le traitement est effectué dans le cadre des activités légitimes d'une fondation, d'une association ou de tout autre organisme à but non lucratif et à finalité politique, philosophique, religieuse, mutualiste ou syndicale. Toutefois, le traitement doit se rapporter aux seuls membres de cet organisme ou aux personnes entretenant avec celui-ci des contacts réguliers liés à sa finalité et que les données ne soient pas communiquées à des tiers sans le consentement des personnes concernées. »

La protection des données personnelles en Afrique et dans le monde

130 pays ont adopté des législations sur la protection des données personnelles et 40 autres pays ont des projets de lois en cours d'examen (source[2]). La carte ci-dessous donne un aperçu.



Source : CNIL

Il est important de noter que même dans les pays qui n'ont pas de législation spécifique, il est courant que des traités régionaux, continentaux ou internationaux, ratifiés par ces pays, s'appliquent. Pour l'Afrique, on peut citer en particulier :

- La Convention 108 "Convention pour la protection des données à caractère personnel" du Conseil de l'Europe[3] ratifiée par 55 pays[4]
- La Convention de l'Union Africaine concernant la Cybersécurité et la Protection des données personnelles[5] ratifiée par 14 pays
- L'acte additionnel de la CEDEAO N° A/SA.1/01/10[6] sur la Protection des données personnelles dans les pays de la CEDEAO

[2] https://papers.ssrn.com/sol3/papers.cfm?abstract_id=1951416

[3] https://www.coe.int/fr/web/data-protection/convention108-and-protocol

[4] https://www.coe.int/en/web/conventions/full-list/-/conventions/treaty/108/signatures?p_auth=3ttl02jg

[5] https://au.int/sites/default/files/treaties/29560-treaty-0048_-_african_union_convention_on_cyber_security_and_personal_data_protection_e.pdf

[6] https://www.afapdp.org/wp-content/uploads/2018/06/CEDEAO-Acte-2010-01-protection-des-donnees.pdf

Il est important de noter que le paysage actuel de la protection des données personnelles évolue très rapidement dans le monde entier. Ces évolutions sont principalement le fait de 2 facteurs principaux :

- **Le Règlement Général de l'UE sur la Protection des Données (RGPD)**[7] : L'Union Européenne a promulgué un nouveau règlement appelé « le règlement général de l'UE sur la protection des données » qui est entré en vigueur le 25 mai 2018. Comme le dit l'UE, « le règlement général de l'UE sur la protection des données (RGPD) est le changement le plus important dans la réglementation sur la confidentialité des données en 20 ans. La réglementation remodèle fondamentalement la manière dont les données sont traitées dans tous les secteurs, de la santé à la banque et au-delà. ». Ce nouveau règlement sert maintenant de référence pour de nombreux pays et ils mettent à jour leurs anciennes législations pour répondre à cette nouvelle législation perçue comme la réglementation la plus protectrice pour les citoyens. De plus, ce règlement impacte les sociétés qui manipulent des données personnelles de citoyens européens (par exemple des centres d'appel), et oblige les entreprises à être domiciliées dans des pays dont la réglementation est compatible avec le RGPD. De ce fait, de nombreux pays qui hébergent ou souhaitent développer l'hébergement de sociétés européennes qui délocalisent leurs activités (Business Process Outsourcing ou BPO[8]) mettent à jour leur législation pour obtenir cette compatibilité.
- **Les nombreux cas d'exploitations illégales de données personnelles collectées par de grandes entreprises (Facebook, Google, etc.) et utilisées par des entreprises et des gouvernements internationaux pour des activités non éthiques**. Le cas récent le plus connu est l'histoire de Cambridge Analytica[9] où des millions de données personnelles Facebook ont été utilisés à des fins de publicité politique.

[7] https://www.cnil.fr/fr/comprendre-le-rgpd
[8] https://www.lebigdata.fr/bpo-definition
[9] https://fr.wikipedia.org/wiki/Scandale_Facebook-Cambridge_Analytica

Le contexte législatif Ivoirien

Plusieurs textes législatifs régissent en Côte d'Ivoire la gestion des données personnelles. Le texte principal est la Loi N°2013-450 du 19 Juin 2013 relative à la protection des données à caractère personnel fournit un cadre légal pour la protection des données à caractère personnel. La section « définition » de ce document décrit les données qui rentrent dans le cas des données personnelles et celles qui ne peuvent être collectées (Article 21).

L'Article 3 de ce texte définit les entités et les activités couvertes par la loi : « Sont soumis aux dispositions de la présente loi :

- Toute collecte, tout traitement, toute transmission, tout stockage et toute utilisation des données à caractère personnel par une personne physique, l'Etat, les collectivités locales, les personnes morales de droit public ou de droit privé ;
- Tout traitement automatisé ou non de données contenues ou appelées à figurer dans un fichier ;
- Tout traitement de données mis en œuvre sur le territoire national ;
- Tout traitement de données concernant la sécurité publique, la défense, la recherche et la poursuite d'infractions pénales ou la sûreté de l'Etat, sous réserve des dérogations définies par des dispositions spécifiques fixées par d'autres textes de loi en vigueur. »

Il est important de bien saisir le dernier élément et notamment la dernière phrase qui indique que certains traitements de données personnelles sont exemptés des dispositions de la loi quand des « dispositions spécifiques » sont « fixées par d'autres textes de loi en vigueur ». Cette disposition indique que certaines données personnelles ne sont pas couvertes par la loi. Il s'agit en général des registres publics de différentes natures pour lesquels les données personnelles peuvent être publiées. On peut citer par exemple les diplômes d'état comme le Baccalauréat dont les résultats d'admission sont publiés au journal officiel. De la même manière dans le registre des sociétés, le nom des responsables légaux sont publics, ainsi que les actionnaires pour certaines formes juridiques. Il est donc important de retenir que la publication de données personnelles est permise dans des cas précis.

L'Article 4 définit deux exceptions :

- « Les traitements de données mis en œuvre par une personne physique dans le cadre exclusif de ses activités personnelles ou domestiques, à condition toutefois que les données ne soient pas destinées à une communication systématique à des tiers ou à la diffusion ; »
- « Les copies temporaires faites dans le cadre des activités techniques de transmission et de fourniture d'accès à un réseau numérique, en vue du stockage automatique, intermédiaire et transitoire des données et à seule fin de permettre à d'autres destinataires du service le meilleur accès possible aux informations transmises. »

La loi institue un ensemble d'obligations :

- Article 5 : « Le traitement des données à caractère personnel est soumis à une déclaration préalable auprès de l'Autorité de protection des données à caractère personnel. » A noter que cet article stipule que chaque traitement différent doit faire l'objet d'une déclaration spécifique. Toutefois l'Article 6 définit plusieurs exceptions de déclarations
    - « Le traitement de données utilisées par une personne physique dans le cadre exclusif de ses activités personnelles, domestiques ou familiales »
    - « Le traitement de données concernant une personne physique dont la publication est prescrite par une disposition légale ou réglementaire »
    - « Le traitement de données ayant pour seul objet la tenue d'un registre qui est destiné à un usage exclusivement privé ; »
    - « Le traitement pour lequel le responsable a désigné un correspondant à la protection des données à caractère personnel est chargé d'assurer, d'une manière indépendante, le respect des obligations prévues dans la présente loi, sauf lorsqu'un transfert de données à caractère personnel à destination d'un pays tiers est envisagé. »
- L'Article 7 définit les traitements spécifiques qui en plus de la déclaration nécessitent une autorisation préalable :
    - « Le traitement des données à caractère personnel portant sur des données génétiques, médicales et sur la recherche scientifique dans ces domaines ; »
    - « Le traitement des données à caractère personnel portant sur des données relatives aux infractions, aux condamnations ou aux mesures de sûreté prononcées par les juridictions ; »
    - « Le traitement portant sur un numéro national d'identification ou tout autre identifiant de la même nature, notamment les numéros de téléphones ; »
    - « Le traitement des données à caractère personnel comportant des données biométriques ; »
    - « Le traitement des données à caractère personnel ayant un motif d'intérêt public notamment à des fins historiques, statistiques ou scientifiques ; »
    - « Le transfert de données à caractère personnel envisagé à destination d'un pays tiers. »

La déclaration ou la demande d'autorisation peut être adressée à l'Autorité de protection par voie électronique, postale ou par tout autre moyen contre remise d'un accusé de réception (Article 10). L'Autorité de protection se prononce dans un délai d'un mois à compter de la réception de la déclaration ou de la demande d'autorisation. Toutefois, ce délai peut être prorogé d'un mois supplémentaire sur décision motivée de l'Autorité de protection. L'absence de réponse de l'Autorité de protection dans le délai imparti équivaut à un rejet de la déclaration ou de la demande d'autorisation (Article 11).

La loi institue la fonction de correspondant à la protection des données à caractère personnel (Article 12) agréé par L'Autorité de protection. L'arrêté n° 511/MPTIC/CAB du 11 novembre

2014[10] portant définition ou profil et fixant les conditions d'emploi du correspondant à la protection des données à caractère personnel détaille le rôle du correspondant.

La loi institue l'Autorité de protection des données à caractère personnel (Articles 46 à 52) et cette fonction est assurée par l'Autorité de Régulation des Télécommunications/TIC de Côte d'Ivoire (ARTCI)[11].

La loi définit les conditions à remplir pour que le traitement des données personnelles soit autorisée :

- La personne dont les données personnelles sont collectées doit donner son consentement (Article 14) sauf dans les cas suivants
    - Respect d'une obligation légale à laquelle le responsable du traitement est soumis ;
    - Exécution d'une mission d'intérêt public ou relevant de l'exercice de l'autorité publique, dont est investi le responsable du traitement ou le tiers auquel les données sont communiquées ;
    - Exécution d'un contrat auquel la personne concernée est partie ou à l'exécution de mesures précontractuelles prises à sa demande ;
    - Sauvegarde de l'intérêt ou des droits et libertés fondamentaux de la personne concernée ;
- La personne dont les données sont collectées doit être averti de :
    - L'identité de l'entité collectant les données (Article 28)
    - La finalité et de l'utilisation prévue des données (Article 18, Article 28)
    - Les catégories de données concernées (Article 28)
    - Le ou les destinataire(s) auxquels les données sont susceptibles d'être communiquées (Article 28)
    - La possibilité de refuser de figurer sur le fichier en cause (Article 28)
    - L'existence d'un droit d'accès aux données concernant la personne et d'un droit de rectification de ces données (Article 28)
    - La durée de conservation des données (Article 28)
    - L'éventualité de tout transfert de données à destination de pays tiers. (Article 28)

    Les données doivent être collectées pour un objectif donné et il n'est pas autorisé de changer la finalité de l'utilisation des données à posteriori. La nature des données collectées doit être en adéquation avec la finalité de l'utilisation. De même, la conservation de ces données doit être en rapport avec le traitement prévu. A la fin de la période de traitement, elles doivent être détruites (Article 14).

[10] https://www.artci.ci/images/stories/pdf/arretes/arrete_profil_correspondant_dcp.pdf
[11] http://www.artci.ci/

- Après la collecte de données, la personne dont les données ont été collectées bénéficie de plusieurs droits
    - Elle peut « demander sous forme de questions et obtenir du responsable de ce traitement :
        - Les informations permettant de connaître et de contester le traitement
        - La confirmation que des données à caractère personnel la concernant font ou ne font pas l'objet de ce traitement
        - La communication des données à caractère personnel qui la concernent ainsi que de toute information disponible quant à l'origine de celles-ci
        - Des informations relatives aux finalités du traitement, aux catégories de données à caractère personnel traitées et aux destinataires ou aux catégories de destinataires auxquels les données sont communiquées. » (Article 29)

      « En cas d'impossibilité d'accès de la personne concernée, le droit d'accès peut être exercé par l'Autorité de protection des données qui dispose d'un pouvoir d'investigation en la matière et qui peut ordonner la rectification, l'effacement ou le verrouillage des données dont le traitement n'est pas conforme à la présente loi. L'Autorité de protection des données communique à la personne concernée le résultat de ses investigations. » (Article 29)

      Cependant « Le responsable du traitement peut s'opposer aux demandes manifestement abusives de la même personne, notamment par leur nombre, leur caractère répétitif ou systématique. En cas de contestation, la charge de la preuve du caractère manifestement abusif des demandes incombe au responsable auprès duquel elles sont adressées. » (Article 29)
    - Elle peut s'« opposer, pour des motifs légitimes tenant à sa situation particulière, à ce que des données à caractère personnel la concernant fassent l'objet d'un traitement, sauf en cas de dispositions légales prévoyant expressément le traitement. En cas d'opposition légitime, le traitement mis en œuvre par le responsable du traitement ne peut porter sur les données en cause ; » (Article 30)
    - Elle peut s'opposer, « sur sa demande et gratuitement, au traitement de données la concernant à des fins de prospection ; » (Article 30)
    - Elle peut demander à être « informée avant que des données la concernant ne soient pour la première fois communiquées à des tiers ou utilisées pour le compte de tiers à des fins de prospection et de se voir expressément accorder le droit de s'opposer, gratuitement, à ladite communication ou utilisation. » (Article 30)
    - Elle peut « exiger du responsable d'un traitement que soient, selon les cas, rectifiées, complétées, mises à jour, verrouillées ou supprimées les données à caractère personnel la concernant, qui sont inexactes, incomplètes, équivoques, périmées, ou dont la collecte, l'utilisation, la communication ou la conservation est interdite. » (Article 31)

- Elle « a le droit d'obtenir du responsable du traitement l'effacement de données à caractère personnel la concernant et la cessation de la diffusion de ces données, en particulier en ce qui concerne des données à caractère personnel que la personne concernée avait rendues disponibles lorsqu'elle était enfant, ou pour l'un des motifs suivants :
  - Les données ne sont plus nécessaires au regard des finalités pour lesquelles elles ont été collectées ou traitées ;
  - La personne concernée a retiré le consentement sur lequel est fondé le traitement ou lorsque le délai de conservation autorisé a expiré et qu'il n'existe pas d'autre motif légal au traitement des données ;
  - La personne concernée s'oppose au traitement des données à caractère personnel la concernant lorsqu'il n'existe pas de motif légal audit traitement ;
  - Le traitement des données n'est pas conforme aux dispositions de la présente loi ;
  - Pour tout autre motif légitime. » (Article 33)

- L'entité en charge du traitement doit mettre en œuvre toutes les mesures possibles pour la protection des données personnelles (Article 19, Article 40, Article 41). L'entité doit établir un rapport annuel notamment concernant les dispositions spécifiques de l'Article 41 sur les mesures de sécurité mises en place.
- Si L'entité responsable du traitement des données personnelles utilise des sous-traitants, elle dit s'assurer du respect de la loi par ces sous-traitants (Article 20)

La loi (Article 26) interdit la communication de données personnelles à un pays tier sauf si ce pays a une législation au moins égale ou supérieure en termes de protection à celle de la Cote d'Ivoire et seulement après autorisation de l'Autorité de protection.

La loi (Article 21, Article 22, Article 45) définit les risques encourus par les contrevenants qui incluent à la fois des amendes (jusqu'à 40 000 000 Francs CFA) et des peines de prison (jusqu'à 20 ans) qui varient en fonction des infractions. L'ARTCI a également pouvoir de sanction pour les contrevenants (Article 51) pour des amendes (maximum de 10 000 000 francs CFA, porté dans le cas de récidive à 100 000 000 francs CFA pour le responsable du traitement et 500 000 000 francs CFA ou 5% de leur chiffre d'affaire pour les entreprises).

A noter enfin que la loi n'inclut aucune disposition spécifique en cas de problème de sécurité, d'accès non-autorisé à des données personnelles ou le vol de ces données. Cependant, l'arrêté n° 511/MPTIC/CAB du 11 novembre 2014 portant définition ou profil et fixant les conditions d'emploi du correspondant à la protection des données à caractère personnel inscrit dans les missions du correspondant (Article 10) « Notifier à l'ARTCI toute violation de la législation en matière de protection des données à caractère personnel préalablement signalée et non corrigée dans un délai de 3 mois à compter du signalement »

Mise en œuvre opérationnel de la protection des données personnelles

Les chapitres précédents avaient pour but de faire prendre conscience aux participants du contenu de loi. Il est maintenant essentiel de comprendre l'impact de ces législations dans la mise en œuvre de la collecte, du stockage, de la manipulation et du partage de données personnelles. L'objet de cette section et de fournir des éléments pratiques de mise en œuvre et notamment les bonnes pratiques pour aborder les questions clés :

- Est-ce que les activités de ma structure relèvent de la protection des données personnelles ?
- Si oui, que dois-je faire :
    - Globalement au sein de structure
    - Spécifiquement lors d'une activité donnée

Les entités et les activités qui relèvent de la protection des données personnelles

Les entités qui relèvent de la protection des données personnelles et qui doivent se soumettre aux obligations de la loi sont celles qui collectent, stockent, collectent et partagent des données personnelles quelles qu'elles soient. Cependant, quand il s'agit de gestion courant classique (par exemple gestion du personnel), il ne sera pas nécessaire de prendre des dispositions spécifiques, dans la mesure où les données collectées sont en rapport avec leur utilisation. Dans tous les autres cas, il sera nécessaire à l'entité de prendre des mesures spécifiques présentées ci-dessous.

Quelques cas ci-dessous illustrent les traitements de données qui relèvent ou pas de la protection des données personnelles :

- **La gestion du personnel** : toute entreprise ayant des salariés collectent les informations nécessaires à la réalisation des activités telles que l'établissement des feuilles de paie et les déclarations aux organismes sociaux. Ces activités ne relèvent pas de la protection des données personnelles
- **La gestion des membres d'une association** : une association (par exemple une coopérative agricole) répertorie la liste de ces membres (nom, prénom, adresse, etc.). Cette activité relève du traitement d'informations à caractère personnel et nécessite donc la mise en place des procédures prévues par la loi
- **L'organisation d'une enquête statistique :** l'organisation d'enquête statistique (par exemple enquête d'opinion) n'inclut généralement pas la capture d'information personnelle et donc ne relève pas de cette législation.
- **La tenue d'un annuaire des fournisseurs :** La tenue d'un annuaire des fournisseurs d'une entreprise, dans la mesure où les informations de ces fournisseurs sont publiques, ne sont pas considérés comme des données personnelles.
- **La tenue d'un annuaire des clients** : La tenue d'un fichier client par une entreprise quand il a pour but unique de servir à la facturation relève des activités classiques d'une entreprise et ne relève de la protection des données personnelles. Par contre, dès que l'entreprise fait des traitements sur ses clients (par exemple rassembler

l'ensemble des factures d'un même client pour identifier les meilleurs clients, analyser les achats pour adapter des promotions à chaque client, envoyer des informations aux clients, etc.), cela relève de la protection des données personnelles.

Les démarches générales

Dans la mesure où une entité relève de la législation relative à la protection des données personnelles, elle a l'obligation de nommer un correspondant à la protection des données à caractère personnel. Le correspondant doit avoir un profil adéquat décrit dans l'arrêté n° 511/MPTIC/CAB du 11 novembre 2014 portant définition ou profil et fixant les conditions d'emploi du correspondant à la protection des données à caractère personnel. Ce correspondant peut-être soit une personne physique soit une personne morale (société, association, etc.). Dans le premier cas, la personne physique ne peut-être correspondant que d'une seule entité. Dans le deuxième cas la personne morale peut être correspondant pour plusieurs entités. Le profil requis pour qu'une personne physique puisse être un correspondant (Article 4 de l'arrêté) :

- Avoir la nationalité ivoirienne
- Avoir un niveau Bac+4 dans les sciences juridiques ou en informatique / réseaux / télécommunication / TIC
- Avoir au moins 5 années d'expérience professionnelle
- Avoir des compétences dans la protection des données personnelles
- Avoir une bonne connaissance des systèmes de gestion de données et des politiques de sécurité des systèmes d'informations de l'organisation pour laquelle il est correspondant
- Maitriser les outils bureautiques et internet
- Avoir d'excellentes capacités organisationnelles et relationnelles
- Ne pas avoir fait l'objet d'une condamnation pénale définitive ou d'une interdiction définitive ou temporaire d'exercer une activité émise par une juridiction ivoirienne ou étrangère. Ne pas avoir fait l'objet d'une sanction de la part de l'ARTCI.

Pour les personnes morales :

- Être une entité de droit ivoirien
- Être à jour des contributions fiscales et sociales
- Exercer une activité dans les sciences juridiques ou en informatique / réseaux / télécommunication / TIC depuis au moins 5 ans
- Avoir une assurance pour les risques professionnels couvrant la protection des données personnelles
- Avoir des personnels ayant au minimum le profil d'un correspondant décrit ci-dessus

Les personnes morales doivent obtenir un agrément de l'ARTCI avant de pouvoir être nommé correspondant par une entité.

Une fois le correspondant identifié, l'entité doit notifier l'ARTCI par courrier avec accusé de réception. Cette notification doit comporter les informations suivantes :

- Le nom, prénom, profession et coordonnées professionnelles du responsable du traitement (l'entité) ou de son représentant légal
- Le nom, prénom, profession et coordonnées professionnelles du correspondant proposé. Dans le cas d'une personne morale, il doit être fait mention de la forme juridique, la dénomination, le siège social, ainsi que les nom, prénom, fonction et coordonnées du représentant légal.
- Les liens juridiques entre le correspondant et l'entité
- Les qualifications ou références professionnelles du correspondant ainsi qu'un CV (personne physique)
- Une copie de la lettre d'acceptation de la fonction par le correspondant
- Il doit être fait mention de l'étendu de la mission du correspondant (s'il couvre la totalité des traitements de données de l'entité ou de seulement un sous-ensemble des traitements qui doivent être listés)
- Enfin il doit être mentionné les mesures prises pour que le correspondant remplisse sa mission en toute indépendance et en toute transparence

La même procédure s'applique lors du remplacement d'un correspondant.

L'ARTCI a 30 jours pour rejeter le correspondant. La non-réponse vaut approbation. Le correspondant peut alors débuter sa mission.

Les tâches du correspondant sont décrites à l'Article 10 de l'arrêté :

- Tenir à jour la liste des traitements effectués
- Détenir les codes et autres mots de passe pour accéder aux fichiers relatifs aux traitements
- Assurer l'accès aux informations personnelles à toute personne qui souhaite exercer un droit reconnu par la loi
- Veiller au respect de la législation en matière de protection des données personnelles
- Signaler au responsable de l'entité les violations constatées de la législation relative à la protection des données
- Notifier à l'ARTCI toute violation constatée, signalée et non corrigée dans un délai de trois mois après la notification du responsable

Les démarches spécifiques lors de la mise en place d'un traitement de données personnelles

Les mesures à appliquer pour se conformer à la législation sur la protection des données personnelles lors de la mise en place d'une collecte de données touchent à plusieurs étapes, et il est essentiel d'intégrer ces mesures dès la conception du projet.

La prise en compte de la protection des données personnelles doit se faire au 3 étapes clés du processus de collecte de données clés :

1. Etape 1 : La conception de la collection de données
2. Etape 2 : La collection de données
3. Etape 3 : L'exploitation des données collectées

La protection des données personnelles impacte également plusieurs catégories de personnes :

- Les collecteurs de données/enquêteurs
- Les services informatiques
- Tous les partenaires ou sous-traitant fournisseurs de services (solutions techniques de collecte de données, etc.) ou utilisateur des données collectées

Étape 1 : Conception d'un processus de collecte de données

La phase de préparation est généralement la phase la plus importante et aussi la plus lourde en termes de mesures à mettre en œuvre. Une fois la liste des données à collecter finalisée, les étapes suivantes doivent être mises en œuvre :

1. **Déclaration officielle** : Toute nouvelle collecte de données doit faire l'objet d'une déclaration. Dans certains cas, elle doit faire l'objet d'une autorisation (voir les sections correspondantes dans la première partie du cours).
2. **Analyse du partenaire/solution technique** : Si le processus de collecte de données implique un partenaire technique ou utilise des solutions techniques qui ne sont pas entièrement installées et hébergées au sein de l'organisation organisant la collecte, il est essentiel de conduire une analyse de ce partenaire et/ou des solutions techniques, dans la mesure où ils seront en contact avec les données personnelles collectées. Il est important de mener une analyse détaillée de toutes les composantes techniques :
    - **Logiciel de collection de données :** Si pour la collecte de données, l'organisation utilise un logiciel, il est essentiel de vérifier les caractéristiques de ce logiciel. S'il s'agit d'un logiciel autonome installé sur les équipements de l'organisation, il n'y a pas de problème particulier. Par contre, si la solution utilisée est un logiciel de type SaaS[12] avec une plateforme en ligne qui héberge les données, il sera nécessaire de mener des investigations supplémentaires présentées ci-dessous.
    - **Solution de stockage des données temporairement ou non :** Si les données sont stockées en dehors des serveurs de l'organisation, il sera nécessaire de mener des investigations supplémentaires.
    - **Solution de sauvegarde des données :** Si les données personnelles sont sauvegardées et les sauvegardes hébergées en dehors de l'organisation, il sera nécessaire de mener des investigations supplémentaires.
    - **Externalisation de la collecte de données (solution technique uniquement ou solution complète avec enquêteurs) :** Si une partie de la collecte est externalisée auprès d'un partenaire extérieur dont le personnel aura accès aux

[12] https://fr.wikipedia.org/wiki/Logiciel_en_tant_que_service

données personnelles sous quel que format que ce soit (papier ou électronique), il sera nécessaire de mener des investigations supplémentaires.

Dans la mesure où l'analyse détaillée a identifié qu'un tiers, soit un sous-traitant soit un fournisseur de logiciel ou de service informatique a accès aux données personnelles collectées, il est important de conduire des investigations plus détaillées qui doivent s'assurer que :

- L'entité qui fournit le service est habilité et respecte les dispositions légales (nomination d'un correspondant auprès de l'ARTCI, mise en place des protections nécessaires, etc.)
- Les données personnelles ne quitteront pas le territoire national.

3. **Accord de collecte et de partage de données** : L'une des étapes clés de la protection des données personnelles est d'informer les individus sur la justification de la collecte de données, les informations à collecter et les accords de partage de données avec des tiers. Afin de répondre à ces 3 points, l'approche la plus efficace consiste à concevoir un accord de collecte et de partage de données qui intégrera ces éléments, et qui sera ensuite présenté à chaque personne dont les données personnelles sont collectées. L'accord doit être rédigé en termes simples et clairs (par opposition à un jargon juridique) afin qu'il soit facilement compréhensible pour la personne concernée. Pour les aspects de partage de données, il y a un compromis à faire. Il n'est ni pratique ni efficace de répertorier toutes les organisations qui auront accès aux informations, car tout nouvel accord avec un tiers nécessitera une mise à jour de l'accord et une nouvelle capture du consentement sur la nouvelle version. Cependant, il est essentiel de développer la confiance pour identifier explicitement les différentes catégories d'acteurs tels que les acteurs publiques (ou non) ou les types de prestataire de services, et l'utilisation autorisée des informations pour chacun de ces types d'acteurs. Si la collecte prévoit une utilisation des données personnelles pour du démarchage (publicités, etc.), il est requis de mentionner cette activité de façon explicite et de la décrire précisément.

4. **Information concernant la correction des données collectées ou la de désinscription** : L'organisation en charge doit mettre en œuvre un processus permettant à quiconque de mettre à jour ses informations ou demander sa désinscription du fichier de l'organisation. Le processus et les informations de contact du correspondant doit être clairement indiqué dans l'accord de collecte et de partage des données et doit être facilement accessible aux personnes. Un moyen simple de mettre en œuvre ce processus consiste à fournir un numéro de téléphone à appeler pour ces actions.

5. **Formulaire de collecte de données** : Le formulaire de collecte de données (papier ou numérique) doit inclure des questions spécifiques :

- La capture explicite du fait que la personne a obtenu une présentation détaillée de l'accord de collecte et de partage des données et l'a compris
- La capture explicite du consentement de la personne à participer à la collecte de données

- Il est également recommandé d'ajouter une question capturant le fait que la personne est sensibilisée à ses droits concernant la mise à jour ou la désinscription

Il est particulièrement essentiel de prendre en compte les restrictions imposées par la loi en ce qui concerne la collecte des données dites « sensibles » présentées dans le chapitre sur Le contexte législatif Ivoirien.

6. **Formation du personnel de l'organisation** : le personnel de l'organisation en charge de la collecte doit être formé à la sensibilité des données personnelles et au besoin de confidentialité pour s'assurer qu'il comprend l'importance de protéger la vie privée des personnes. Cette formation inclura la présentation des sanctions et pénalités pénales et financières en cas de non-respect de la loi. Cette formation devra s'appliquer à l'ensemble du personnel ayant accès aux données personnelles collectées.

7. **Formation des collecteurs de données** :

- Les collecteurs de données devront également être formés à la sensibilité des données personnelles et au besoin de confidentialité de la même manière que le personnel de l'organisation. Dans le cas de la collecte sur papier, des mesures spécifiques de protection du papier devraient être incluses. Dans le cas de la collecte basée sur les TIC, la formation devrait inclure des mesures pour protéger l'équipement, la nécessité d'avertir l'organisation dès qu'une violation est détectée ou l'importance de ne pas divulguer les identifiants d'accès.
- Les collecteurs de données devront également être spécifiquement formés à la présentation de l'accord de collecte et de partage des données, qui est la pierre angulaire de la protection des données personnelles.

8. **Protection des équipements mobiles** : pour une collecte de données basée sur les TIC, les logiciels et les équipements mobiles utilisés doivent implémenter des fonctionnalités de protection de base. Ceci comprend notamment :

- *L'utilisation d'un identifiant / mot de passe pour accéder aux données de l'équipement*. De nombreux outils de collecte de données ne nécessitent pas l'authentification du collecteur de données et le système central authentifie l'équipement mobile. Une telle approche devrait être interdite. En effet, si un collecteur de données perd l'équipement mobile, quiconque le trouve peut accéder aux données personnelles déjà collectées et disponibles sur la tablette et pourrait même polluer le système central en envoyant de fausses données. Même si le processus de connexion est lourd, c'est un élément de sécurité essentiel. La connexion doit également inclure une déconnexion automatique après une période d'inactivité.
- *La possibilité d'effacer à distance les équipements* : tous les équipements modernes offrent de nos jours un mécanisme d'effacement à distance de toutes les données dont ils disposent après perte ou vol de l'équipement. Les systèmes d'exploitation comme Android ou iOS offrent aux utilisateurs la possibilité de déclarer leur équipement perdu et à la prochaine connexion en ligne, l'équipement est effacé et bloqué. Cependant,

ces fonctionnalités doivent être installées et activées avant d'être disponibles. L'équipement doit donc être préparé en conséquence avant d'être fourni aux collecteurs de données.

9. **Exigences du système central de stockage des données** : Le système de stockage central doit également mettre en œuvre une série de mesures spécifiques, notamment :

- *La mise en œuvre de différents niveaux d'accès* : il est essentiel de garantir que des personnes spécifiques n'accèdent qu'aux informations auxquelles elles sont censées accéder. Par exemple, un collecteur de données devrait pouvoir accéder uniquement aux données sur les personnes qu'il interroge. Le système de stockage central doit donc mettre en œuvre un mécanisme d'accès pour garantir que différentes catégories de personnes peuvent accéder au système mais uniquement aux informations auxquelles elles sont autorisées à accéder (et décrites comme telles dans l'accord de collecte et de partage des données).
- *La surveillance de l'accès et la détection des failles de sécurité* : le système de stockage central devra faire l'objet d'une surveillance pour détecter les activités inhabituelles et détecter de manière proactive toute brèche de sécurité. Ces brèches devront être notifiées au correspondant en charge de la protection des données personnelles qui avertira l'ARTCI.

Étape 2 : collecte de données

Au moment de la collecte des données, lorsque tous les éléments sont en place, les tâches les plus importantes à effectuer avant de commencer la collecte des données sont :

- La présentation de l'accord de collecte et de partage des données
- La capture du consentement explicite pendant le processus de collecte des données

La collecte de données ne devrait alors commencer qu'après avoir terminé ces étapes.

Étape 3 : Exploitation des données collectées

Enfin, lorsque les données sont collectées et centralisées sur le système central de stockage, l'organisation en charge de la collecte peut accorder l'accès à des tiers pour qu'ils exploitent et réutilisent les données. À ce stade, l'élément le plus important est le protocole d'accord avec chaque tiers qui doit inclure des paragraphes spécifiques :

- Le protocole d'accord devrait inclure l'utilisation autorisée de l'information (l'élément d'information qui sera utilisé, la justification et les objectifs). Ces éléments doivent également figurer dans l'accord de collecte et de partage des données.
- Le protocole d'accord devrait explicitement interdire au tiers de partager avec toute autre partie les informations ou de publier les informations personnelles.
- Le protocole d'accord devra explicitement exiger du tiers qu'il sensibilise et forme son personnel à l'accès aux informations sur la sensibilité des informations personnelles, la nécessité d'une confidentialité totale et les risques et sanctions juridiques associés.

- Le protocole d'accord devrait exiger explicitement du tiers qu'il signale toute violation de la sécurité

Il est important de noter que l'organisation en charge des données peut décider d'anonymiser les données collectées avant de les partager. Un tel traitement permet d'éviter aux données de devoir répondre à la réglementation sur la protection des données personnelles, et permet un partage et une publication plus large et sans entrave.

Le respect de ces dispositions permettra à l'organisation mettant en œuvre la collecte de données de s'assurer de la conformité avec la loi sur la protection des données à caractère personnel. Il est important de noter que la réexécution d'une même collecte ne nécessite pas une nouvelle analyse complète, ni une nouvelle déclaration à l'ARTCI dans la mesure où aucune condition n'a changé et où il était prévu à l'origine que la collecte de données soit récurrente. Cependant, l'utilisation des données collectées dans un nouveau cadre, ou dans un nouvel objectif non-mentionné dans l'accord de collecte et de partage des données présenté aux personnes impliquées nécessite la mise à jour de cet accord, sa présentation aux personnes impliquées et la capture de leur consentement pour ce nouvel accord.

Conclusion

L'objectif de cette formation est de sensibiliser les participants à la protection des données personnelles, et en particulier des obligations introduites par la Loi N°2013-450 du 19 Juin 2013 relative à la protection des données à caractère personnel. A l'issue de ce module, les participants doivent pouvoir évaluer de façon précise si l'organisation dans laquelle il travaille respecte cette législation, et si ce n'est pas le cas les démarches a effectuées. De la même manière, les participants ont maintenant les outils pour intégrer dans la mise en place de collectes et de traitements de données les mesures nécessaires au respect de la loi.

Evaluation

Remplissez le questionnaire à l'adresse https://bit.ly/2RPy9EE pour vous assurez que vous maitrisez bien tous les concepts présentés dans ce document.

Références

- Loi N°2013-450 du 19 Juin 2013 relative à la protection des données à caractère personnel[13]
- Arrêté n° 511/MPTIC/CAB du 11 novembre 2014 portant définition ou profil et fixant les conditions d'emploi du correspondant à la protection des données à caractère personnel[14]

[13] http://www.artci.ci/images/stories/pdf/lois/loi_2013_450.pdf

[14] http://www.artci.ci/images/stories/pdf/arretes/arrete_profil_correspondant_dcp.pdf

- Loi N°2013-451 du 19 Juin 2013 relative à la lutte contre la cybercriminalité[15]
- Loi N°2013-537 du 30 Juillet 2013 portant organisation du système statistique national[16]
- Loi N°2013-546 du 30 Juillet 2013 relative aux transactions électroniques[17]
- Décret 2015-79 du 4 Février 2015 fixant les modalités de dépôt des déclarations, de présentation des demandes, d'octroi et de retrait des autorisations pour le traitement des données à caractère personnel[18]
- ARTCI[19]
- Foire aux Questions relative aux données à caractère personnel de l'ARTCI[20]

[15] http://www.artci.ci/images/stories/pdf/lois/loi_2013_451.pdf
[16] http://www.ins.ci/n/templates/docss/ins_loi_statistique.pdf
[17] http://www.artci.ci/images/stories/pdf/lois/loi_2013_546.pdf
[18] http://www.artci.ci/images/stories/pdf/decrets/decret_2015_79.pdf
[19] https://www.artci.ci/
[20] https://www.artci.ci/index.php/secteurs-regules/protection-des-donnees/268-la-foire-aux-questions-des-dcp.html